

Applicability & Gap Matrix

Sentinel Nexus — framework coverage, gaps, and remediation

Information Security & AI Governance

June 2026

Contents

Overview 2

Framework Applicability 3

NIST SP 800-53 Rev. 5 — Family Coverage 6

NIST CSF 2.0 — Function & Category Coverage 7

NIST AI 600-1 (GenAI Profile) 9

Outstanding Gaps (addressable) 10

Overview

For each framework taxonomy, every item is classified **Covered** (a Sentinel Nexus control addresses it), **GAP** (applicable but not yet addressed — with a remediation that *can* address it), or **N-A** (not applicable to a defensive SOC platform; see the Applicability Determinations). OWASP/ATLAS coverage is computed from the controls manifest; SP 800-53 titles are the authoritative NIST OSCAL rev5 catalog.

Framework Applicability

OWASP Top 10 for Large Language Model Applications (2023)

Covered 9 · Gaps 1 · N-A 0

ID	Item	Status	Controls	Remediation (if gap)
LLM01	Prompt Injection	Covered	SEC-CANARY, SEC-SANITIZER	—
LLM02	Insecure Output Handling	Covered	SEC-DUCKDB- SANDBOX, SIEM-TOOL-GUARD	—
LLM03	Training Data Poisoning	Covered	SEC-RLHF- QUARANTINE, SEC-TRAINING- HYGIENE, SEC-VECTOR-DIM	—
LLM04	Model Denial of Service	Covered	SEC-MODEL-DOS	—
LLM05	Supply Chain Vulnerabilities	Covered	SEC-FAILOVER	—
LLM06	Sensitive Information Disclosure	Covered	SEC-DLP-EGRESS	—
LLM07	Insecure Plugin Design	Covered	SEC-OUTPUT-SCHEMA	—
LLM08	Excessive Agency	Covered	SEC-BLAST-RADIUS, SEC-DUCKDB- SANDBOX, SEC-OUTPUT-SCHEMA, SIEM-TOOL-GUARD	—
LLM09	Overreliance	Covered	AI-REVIEW-BOARD, SEC- REGRESSION-GATE	—

ID	Item	Status	Controls	Remediation (if gap)
LLM10	Model Theft	GAP	—	Addressable: rate-limit + anomaly-monitor the sovereign inference endpoints and add model-extraction / membership-inference detection; tighten access control and egress monitoring on weight artifacts. SHA-384 verification protects weight INTEGRITY (tampering) but not exfiltration/theft.

MITRE ATLAS — platform-relevant techniques

Covered 6 · Gaps 2 · N-A 1

ID	Item	Status	Controls	Remediation (if gap)
AML.T0042	Verify Attack (prompt-leak tripwire defended)	Covered	SEC-CANARY	—
AML.T0043	Craft Adversarial Data	Covered	SEC-REGRESSION-GATE, SEC-SANITIZER	—
AML.T0015	Evade ML Model	Covered	SEC-REGRESSION-GATE	—
AML.T0044	Full ML Model Access (weight tampering)	Covered	SEC-SUPPLY-CHAIN	—
AML.T0031	Erode ML Model Integrity (reward poisoning)	Covered	SEC-RLHF-QUARANTINE	—
AML.T0020	Poison Training Data	Covered	SEC-RLHF-QUARANTINE, SEC-TRAINING-HYGIENE	—

ID	Item	Status	Controls	Remediation (if gap)
AML.T0024	Exfiltration via ML Inference API (model extraction)	GAP	—	Addressable: detect model-extraction query patterns + membership inference on the internal vLLM endpoints (rate/volume anomaly + canary outputs). Ties to OWASP LLM10 and NIST MS-2.10-001 (POA&M-4).
AML.T0040	ML Model Inference API Access	GAP	—	Addressable: enforce authn/z + per-caller quotas on the sovereign inference endpoints and log/alert on abnormal query volume (currently network-isolated but not rate-monitored).
AML.T0048	Societal Harm	N-A	—	Defensive internal SOC system; not a public content generator (see applicability determinations).

NIST SP 800-53 Rev. 5 — Family Coverage

Authoritative control titles from NIST OSCAL v1.4.0.

Family	Title	Controls referenced
AC	Access Control	AC-17, AC-3, AC-4, AC-6, AC-7
AU	Audit and Accountability	AU-10, AU-12, AU-2, AU-3, AU-6, AU-9
CA	Assessment, Authorization, and Monitoring	CA-2, CA-7
CM	Configuration Management	CM-2, CM-3, CM-7
CP	Contingency Planning	CP-10
IA	Identification and Authentication	IA-5
RA	Risk Assessment	RA-3
SC	System and Communications Protection	SC-16, SC-28, SC-5, SC-6, SC-7, SC-8
SI	System and Information Integrity	SI-10, SI-12, SI-16, SI-3, SI-4, SI-7
SR	Supply Chain Risk Management	SR-11, SR-3, SR-4

NIST CSF 2.0 — Function & Category Coverage

Authoritative function/category titles from NIST OSCAL v1.4.0 (CSF 2.0). Controls are mapped at **category** granularity in `csf_category_map.yaml`.

Of the **22** CSF 2.0 categories, **15** are realised by a technical control; the remaining **7** are organizational / process categories carried by the policy layer (System Security Plan, AI Incident Response Plan, Applicability Determinations) rather than by software.

Fn	Category	Title	Realised by	Coverage
GV Govern	GV.OC	Organizational Context	<i>policy / process — see SSP</i>	Process
GV Govern	GV.OV	Oversight	NC-1-BIAS-AUDIT, NC-11-ENERGY-ACCOUNTING, NC-2-CALIBRATION, NC-6-ENERGY, NC-8-OVER-RELIANCE	Technical
GV Govern	GV.PO	Policy	NC-4-RETENTION	Technical
GV Govern	GV.RM	Risk Management Strategy	<i>policy / process — see SSP</i>	Process
GV Govern	GV.RR	Roles, Responsibilities & Authorities	AI-PROVENANCE	Technical
GV Govern	GV.SC	Cybersecurity Supply Chain Risk Mgmt	NC-3-FRONTIER-PIN, SEC-SUPPLY-CHAIN	Technical
ID Identify	ID.AM	Asset Management	NC-3-FRONTIER-PIN, SIEM-CONFIG-CONTRACT	Technical
ID Identify	ID.IM	Improvement	NC-2-CALIBRATION, NC-9-ACTIVE-LEARNING, SEC-REGRESSION-GATE	Technical
ID Identify	ID.RA	Risk Assessment	<i>policy / process — see SSP</i>	Process
PR Protect	PR.AA	Identity Mgmt, Authn & Access Control	IAC-HARDENING, ING-ZERO-TRUST, SEC-DUCKDB-SANDBOX, SEC-ENDPOINT-ID, SIEM-TOOL-GUARD	Technical
PR Protect	PR.AT	Awareness & Training	<i>policy / process — see SSP</i>	Process

Fn	Category	Title	Realised by	Coverage
PR Protect	PR.DS	Data Security	AI-MEMORY-TTL, ING-ZERO-TRUST, NC-10-VERDICT-LINEAGE, NC-4-RETENTION, SEC-CANARY, SEC-DLP-EGRESS, SEC-RLHF-QUARANTINE, SEC-TRAINING-HYGIENE, SEC-VECTOR-DIM	Technical
PR Protect	PR.IR	Technology Infrastructure Resilience	SEC-BLAST-RADIUS, SEC-FAILOVER, SEC-MODEL-DOS	Technical
PR Protect	PR.PS	Platform Security	IAC-HARDENING, SEC-DUCKDB-SANDBOX, SEC-OUTPUT-SCHEMA, SEC-REGRESSION-GATE, SEC-SANITIZER, SEC-SUPPLY-CHAIN	Technical
DE Detect	DE.AE	Adverse Event Analysis	AI-GROUNDING, AI-REVIEW-BOARD, NC-10-VERDICT-LINEAGE, NC-9-ACTIVE-LEARNING, SIEM-COUNTERPART-DISPROOF	Technical
DE Detect	DE.CM	Continuous Monitoring	IAC-HARDENING, ING-DLQ-BREAKER, ING-ZERO-TRUST, NC-1-BIAS-AUDIT, NC-8-OVER-RELIANCE, SEC-CANARY, SEC-MODEL-DOS, SEC-RLHF-QUARANTINE, SIEM-E2E, SIEM-TOOL-GUARD	Technical
RS Respond	RS.AN	Incident Analysis	AI-REVIEW-BOARD	Technical
RS Respond	RS.CO	Incident Response Reporting & Comms	<i>policy / process — see SSP</i>	Process
RS Respond	RS.MA	Incident Management	<i>policy / process — see SSP</i>	Process

Fn	Category	Title	Realised by	Coverage
RS Respond	RS.MI	Incident Mitigation	SEC-BLAST-RADIUS, SEC-IDEMPOTENT-SOAR, SEC-OUTPUT-SCHEMA	Technical
RC Recover	RC.CO	Incident Recovery Comms	<i>policy / process — see SSP</i>	Process
RC Recover	RC.RP	Incident Recovery Plan Execution	ING-DLQ-BREAKER, SEC-FAILOVER	Technical

Process-layer categories (no code control by design): GV.OC Organizational Context, GV.RM Risk Management Strategy, ID.RA Risk Assessment, PR.AT Awareness & Training, RC.CO Incident Recovery Comms, RS.CO Incident Response Reporting & Comms, RS.MA Incident Management. These are addressed as policy/governance obligations in the System Security Plan and supporting governance documents, consistent with a defensive SOC platform whose mission, risk-tolerance, workforce-training, and incident-management *processes* are organizational rather than implemented in the codebase.

NIST AI 600-1 (GenAI Profile)

The 12 GAI risk families and their coverage/gaps are maintained in `../nist_ai_600_1_control_tracker.md` §1 (e.g. Confabulation, Bias/Homogenization, and Value-Chain are the active high-exposure areas; CBRN/CSAM/violent/IP are N-A per the Applicability Determinations).

Outstanding Gaps (addressable)

These are **applicable** items not yet covered by a control, each with a remediation that can close it. They are candidate backlog items.

- **LLM10 — Model Theft.** Addressable: rate-limit + anomaly-monitor the sovereign inference endpoints and add model-extraction / membership-inference detection; tighten access control and egress monitoring on weight artifacts. SHA-384 verification protects weight INTEGRITY (tampering) but not exfiltration/theft.
- **AML.T0024 — Exfiltration via ML Inference API (model extraction).** Addressable: detect model-extraction query patterns + membership inference on the internal vLLM endpoints (rate/volume anomaly + canary outputs). Ties to OWASP LLM10 and NIST MS-2.10-001 (POA&M-4).
- **AML.T0040 — ML Model Inference API Access.** Addressable: enforce authn/z + per-caller quotas on the sovereign inference endpoints and log/alert on abnormal query volume (currently network-isolated but not rate-monitored).

Theme. The principal residual exposure is **inference-endpoint abuse / model extraction** (OWASP LLM10, ATLAS AML.T0024 / AML.T0040, NIST MS-2.10-001): the sovereign vLLM endpoints are network-isolated but not rate-/anomaly-monitored for extraction or membership-inference query patterns. Remediation is a bounded, testable control (per-caller quotas + query-volume anomaly alerting + a membership-inference review) — tracked as a backlog item and SSP POA&M-4.